

# CRISC Exam - Hard Concepts & Exam Traps

## Section 4: Information Technology and Security Deep Dive Tutorial

CRISC Mastery Series

July 19, 2026

# Section 4 Tutorial Outline

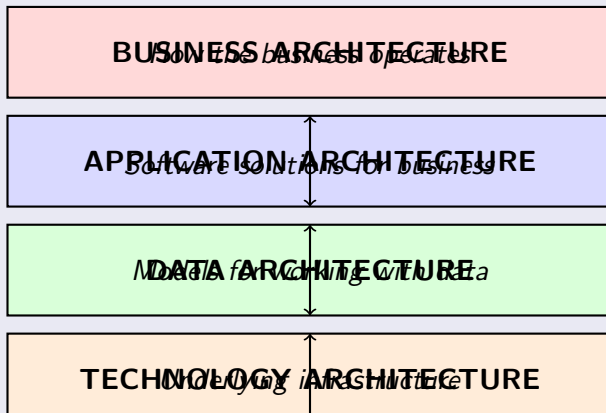
- 1 1. Enterprise Architecture
  - 1.1 Understanding Enterprise Architecture
  - 1.2 Capability Maturity Model
- 2 2. Computer Networks
  - 2.1 Network Models
  - 2.2 Networking Devices
  - 2.3 Firewalls and IDS/IPS
  - 2.4 DNS and VPN
- 3 3. Cloud Computing
  - 3.1 Cloud Service Models
  - 3.2 Cloud Deployment Models
- 4 4. Data Life Cycle Management
  - 4.1 Data Classification
- 5 5. System Development Life Cycle (SDLC)
  - 5.1 SDLC Phases
  - 5.2 Project Risk vs SDLC Risk
- 6 6. Information Security Principles

# 1.1 What is Enterprise Architecture?

## Definition

Enterprise Architecture (EA) is the **foundation** for running any successful business.

## The Four Domains of EA



# 1.1 Architecture Domains Explained

## Business Architecture

- Captures **how** a business operates
- Defines **business processes**
- Defines role of **underlying software**
- Ensures software doesn't become **obsolete**

## Application Architecture

- Defines **software solutions**
- Enables businesses to achieve **objectives**
- Adapts to **changing business requirements**
- Examples: CRM, ERP, HR systems

# 1.1 Data and Technology Architecture

## Data Architecture

- Defines **model** for working with data
- Manages different **sources** and **formats**
- Applications use data to derive **insights**
- Examples: Data warehouses, data lakes, ETL pipelines

## Technology Architecture

- Describes **underlying infrastructure**
- **Physical entities**: Networks, storage, hardware
- Shows **current state** of IT
- Establishes vision for **future state**
- Examples: Networking devices, servers, storage, software

## The Critical Trap

**Technology Architecture** includes **networking devices, storage, and**

# 1.1 Common EA Frameworks

## Popular Frameworks

| Framework | Type                | Best For              |
|-----------|---------------------|-----------------------|
| TOGAF     | Comprehensive       | Large enterprises     |
| Zachman   | Classification      | Framework integration |
| DODAF     | Military/Government | Defense organizations |
| FEAF      | Government          | US Federal agencies   |
| SABSA     | Security-focused    | Security architecture |

## Key Insight

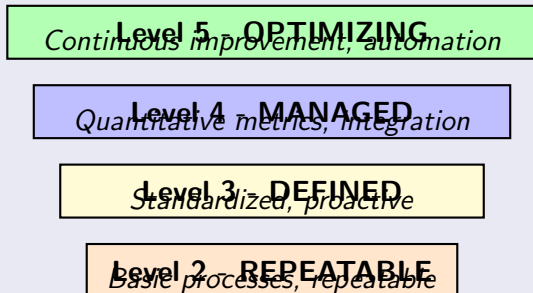
The goal of a risk manager is to ensure that technology architecture evolves with **minimal disruption** to IT and the business.

# 1.2 Understanding CMM

## What is CMM?

- **Capability Maturity Model**
- Developed in 1986 for US Department of Defense
- Assesses and improves process **maturity**
- Later became **CMMI** (Capability Maturity Model Integration)

## The Five Levels



## 1.2 CMM Levels Explained

### Level 0 - Incomplete

- Enterprise does **not recognize** the need
- Decisions **lack credible information**
- No awareness of risk management

### Level 1 - Initial

- Risk viewed as **technical** issue
- **Ad hoc** skills
- **Episodic** risk assessments

### Level 2 - Repeatable

- **Basic processes** exist
- Risk viewed as business issue *in IT*
- Some **repeatability**



## 1.2 Levels 3-5

### Level 3 - Defined

- Risk viewed as **business issue**
- Business knows how IT fits in **enterprise risk universe**
- **Workflow tools** used
- Processes are **standardized**
- **Proactive** rather than reactive

### Level 4 - Managed

- **Quantitative metrics** used
- Integrated with **ERM**
- Data-driven decisions

### Level 5 - Optimizing

- **Real-time monitoring**
- **Automation** of policy management

# 2.1 TCP/IP Model

## TCP/IP Layers

**Application Layer (Layer 5)**  
User interface, HTTP, FTP, DNS

**Transport Layer (Layer 4)**  
TCP (reliable), UDP (unreliable)

**Network Layer (Layer 3)**  
IP addressing, routing

**Data Link Layer (Layer 2)**  
MAC addressing, frames

**Physical Layer (Layer 1)**  
Physical infrastructure, signals

## The Critical Trap

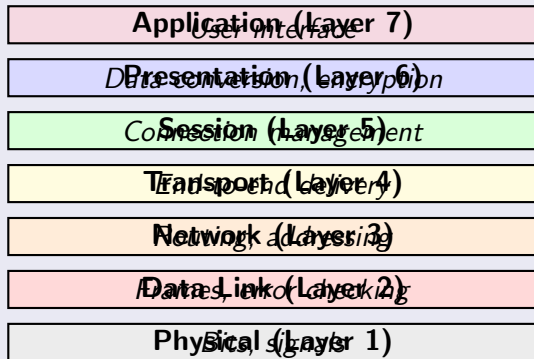
**Network Layer** = IP addressing (Layer 3)

**Transport Layer** = TCP/UDP (Layer 4)

**Application Layer** = User-facing protocols (Layer 5)

# 2.1 OSI Model

## OSI Layers



## 2.1 TCP/IP vs OSI

### Key Differences

| Feature            | TCP/IP                   | OSI                      |
|--------------------|--------------------------|--------------------------|
| Layers             | 5 layers                 | 7 layers                 |
| Session Layer      | Not separate             | Separate layer (Layer 5) |
| Presentation Layer | Not separate             | Separate layer (Layer 6) |
| Purpose            | Practical implementation | Conceptual framework     |
| Approach           | Implemented              | Theoretical              |

### Key Insight

TCP/IP is **implemented** in practice.

OSI is a **conceptual** framework for understanding networks.

## 2.2 Networking Devices

### Device Overview

| Device   | OSI Layer           | Function                         |
|----------|---------------------|----------------------------------|
| Repeater | Layer 1 (Physical)  | Regenerates signal               |
| Bridge   | Layer 2 (Data Link) | Joins two networks               |
| Switch   | Layer 2 (Data Link) | Multi-port bridge, MAC addresses |
| Router   | Layer 3 (Network)   | Connects networks, IP addresses  |
| Gateway  | Layer 3+            | Connects different protocols     |

### The Critical Trap

- **Switch** = MAC addresses (Layer 2)
- **Router** = IP addresses (Layer 3)
- **Gateway** = Different protocols (Layer 3+)

## 2.3 Firewall Types

### Firewall Types

| Type                      | OSI Layer | Description               |
|---------------------------|-----------|---------------------------|
| Packet Filtering          | Layer 3   | Compares packets to rules |
| Circuit-Level Gateway     | Layer 5   | Monitors TCP handshakes   |
| Application-Level Gateway | Layer 7   | Examines each layer       |
| Stateful Inspection       | Layer 3   | Tracks connections        |
| Next-Generation           | Layer 7   | Deep packet inspection    |

### Key Insight

**Application-Level Gateway** = Most secure (Layer 7)

**Next-Generation** = Most advanced (Layer 7 + IPS)

## 2.3 IDS vs IPS

### Intrusion Detection Systems (IDS)

- **Detects** potential malicious traffic
- **Does NOT block** traffic
- Sends **alerts** to security teams
- **Passive** system
- **No effect** on network throughput

### Intrusion Prevention Systems (IPS)

- **Detects AND blocks** malicious traffic
- **Active** system
- Implemented **in-line** with traffic
- May **reduce** network throughput
- Also called **IDS with blocking** capability

## 2.4 Domain Name System (DNS)

### What is DNS?

- Acts as a **directory** for internet domain names
- Translates **domain names** to **IP addresses**
- Example: [www.grcmusings.com](http://www.grcmusings.com) → 162.241.252.221
- Critical for **user-friendliness**
- Application Layer protocol (Layer 7)

### Finding IP Address

- Use **ping** command in Command Prompt
- Example: `ping grcmusings.com`
- Shows the IP address of the domain



## 2.4 Virtual Private Network (VPN)

### What is a VPN?

- Creates a **secure, encrypted tunnel**
- Over a **less secure** network (public internet)
- Provides **remote access** to private networks
- **Encrypts** all traffic
- Protects data from **interception**

### VPN Protocols

- **IPSec** - Most secure (Network Layer)
- **SSL/TLS** - Transport Layer
- **PPTP** - Older, less secure
- **L2TP** - Older, less secure

### The Critical Trap

**IPSec** is the **MOST SECURE** VPN protocol.

## 3.1 Cloud Service Models

### The Three Service Models

#### **Infrastructure as a Service (IaaS)**

Compute, Storage, Networking

Examples: AWS, Azure

Examples: AWS Elastic Beanstalk, Google App Engine

#### **Platform as a Service (PaaS)**

Development Platform

#### **Software as a Service (SaaS)**

Examples: Gmail, Office 365

Ready-to-use Applications

## 3.2 Cloud Deployment Models

### The Four Deployment Models

| Model            | Description              | Use Case                      |
|------------------|--------------------------|-------------------------------|
| <b>Public</b>    | Shared by general public | Broad access, SaaS            |
| <b>Private</b>   | Dedicated to one org     | High security, sensitive data |
| <b>Community</b> | Shared by similar orgs   | Research, government          |
| <b>Hybrid</b>    | Combination of models    | Cloud bursting, migration     |

### The Critical Trap

- **Public** = Open to all
- **Private** = **NOT** shared with anyone
- **Community** = Shared with **similar** organizations
- **Hybrid** = Mix of public and private

## 3.2 Security Considerations

### Key Security Concerns

- **Shared Responsibility:** Understand provider vs customer responsibilities
- **SLAs:** Ensure security is included
- **Data Breaches:** Encryption, access controls, monitoring
- **Compliance:** Provider must be compliant
- **Disaster Recovery:** Backup and recovery plans
- **IAM:** Strong authentication, MFA
- **Vendor Lock-in:** Avoid dependency on single provider

### AWS Shared Responsibility Model

- **AWS** responsible for: Security **of** the cloud
- **Customer** responsible for: Security **in** the cloud

# 4.1 Data Classification

## Why Classify Data?

- Determines **sensitivity** of data
- Defines **controls** required
- **Directly impacts** cost of controls
- Enables **appropriate** protection

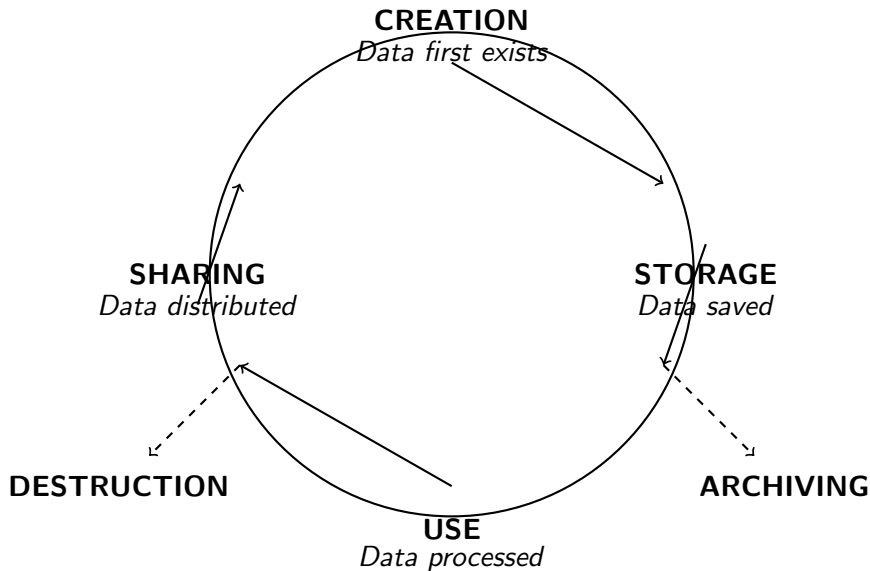
## Classification Factors

- **Regulatory requirements:** HIPAA, GDPR, PCI-DSS
- **Business impact:** Critical vs Public
- **Type:** PII, financial, health records
- **Access control:** Restricted vs Public
- **Location:** On-premises vs Cloud

## The Critical Trap

**Data Owner** classifies the data.

## 4.1 Data Life Cycle



# 4.1 Data Life Cycle Stages

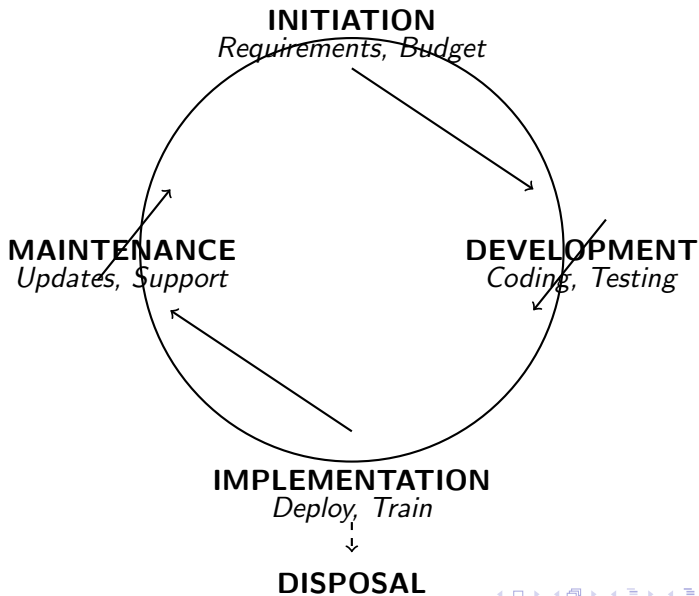
## The Six Stages

- 1 **Creation:** Data first comes into existence
- 2 **Storage:** Data is stored and available
- 3 **Use:** Data is processed for output
- 4 **Sharing:** Data is shared with others
- 5 **Archiving:** Data is stored for compliance
- 6 **Destruction:** Data is securely destroyed

## Key Insight

More **sensitive** classification = **stronger** controls at each stage.

## 5.1 The SDLC Phases





# 5.1 Phase 1 - Initiation

## Initiation Phase

- **First** phase of SDLC
- Evaluate project **feasibility**
- Define goals and **objectives**
- Identify **stakeholders**
- Gather **requirements**
- Create **project charter**
- **Budgeting** occurs here

## Risks in Initiation

- Unclear project **goals**
- Lack of **stakeholder support**
- Inadequate **budget** or **resources**
- Inaccurate project **requirements**

## 5.1 Phases 2-3

### Phase 2 - Development/Acquisition

- **Actual coding** takes place
- Software created based on specifications
- Acquire software if not building
- **Testing** is critical

### Phase 3 - Implementation

- **Install** the software system
- **Train** end users
- **Configure** and enable security
- Verify security **configurations**

### The Critical Trap

**End user training** occurs in the **IMPLEMENTATION** phase.

**Budgeting** occurs in the **INITIATION** phase.

## 5.1 Phases 4-5

### Phase 4 - Operation/Maintenance

- System is **deployed**
- Focus: Ensure system **functions** as intended
- Address issues **promptly**
- Activities: Monitoring, bug fixes, updates, enhancements

### Phase 5 - Disposal

- **FINAL** stage of SDLC
- Remove system from **operation**
- **Secure destruction** of data
- Decommission hardware and software
- Ensure **no unauthorized access**

### The Critical Trap

**Disposal** is the **FINAL** phase of SDLC.

## 5.2 Project Risk vs SDLC Risk

### Project Risk

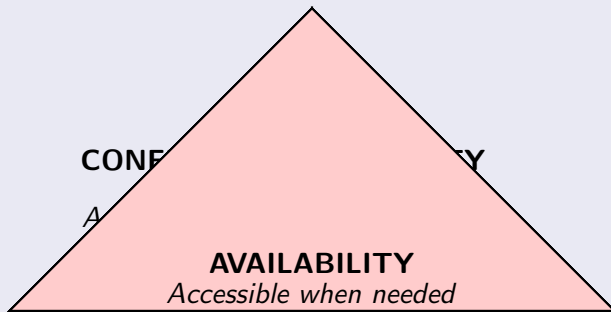
- Risk associated with achieving **project objectives**
- Examples:
  - Delivering on **time**
  - Staying **within budget**
  - Meeting **requirements**
- Can be **external** (market changes) or **internal** (delays)

### SDLC Risk

- Risk associated with the **development process**
- Examples:
  - **Requirements** gathering issues
  - **Design** flaws
  - **Coding** errors
  - **Testing** gaps
- Managed through **best practices** and **standards**

## 6.1 The CIA Triad

Confidentiality, Integrity, Availability



## 6.1 CIA Definitions

### Confidentiality

- Information accessible to **authorized users only**
- Protected from **unauthorized disclosure**
- **Need-to-know** principle
- **Least privilege** principle

### Integrity

- Information is **accurate** and **complete**
- Has NOT been **tampered** with
- Protected from **unauthorized modification**
- Ensures information is **trustworthy**

### Availability

- Information accessible to **authorized users when needed**
- Ensures **uninterrupted access**

# 6.1 CIA Trade-offs

## The Three-way Trade-off

- You **cannot** maximize all three simultaneously
- Trade-offs are **always** necessary

## Confidentiality vs Availability

- **Increasing Confidentiality:** More encryption, more authentication
- **Effect on Availability:** **Decreases** availability
- **Why:** More processing time, slower access

## Integrity vs Availability

- **Increasing Integrity:** More validation, more checks
- **Effect on Availability:** **Decreases** availability
- **Why:** Slows processing, delays access

## 6.2 The IAAA Framework

### IAAA - Four Pillars of Access Management

| Pillar                | Description             | Example             |
|-----------------------|-------------------------|---------------------|
| <b>Identification</b> | Unique ID for each user | Username, email     |
| <b>Authentication</b> | Prove identity          | Password, biometric |
| <b>Authorization</b>  | Define permissions      | Role-based access   |
| <b>Accountability</b> | Log and monitor         | Audit trails        |

### The Critical Trap

- **Identification** = "Who are you?" (Username)
- **Authentication** = "Prove it" (Password)
- **Authorization** = "What can you do?" (Permissions)
- **Accountability** = "What did you do?" (Logging)



## 6.2 Multi-Factor Authentication

### Three Authentication Factors

- **Something You Know:** Password, PIN, Security Questions
- **Something You Have:** Smart card, Token, Phone
- **Something You Are:** Fingerprint, Retinal scan, Voice

### MFA Implementation

- Uses **two or more** factors
- Example: Password + Fingerprint
- Much **more secure** than single factor
- **Recommended** for all systems

### Key Insight

Username + Password = **Single Factor** (Not MFA)

Password + Fingerprint = **Multi-Factor**

## 6.2 Segregation of Duties (SOD)

### What is SOD?

- **Prevents** internal fraud
- No single individual has **complete control**
- **Distributes** access across multiple people
- **Prevents** conflicts of interest
- **Required** for SOX and PCI DSS compliance

### SOD Example

- Person **A** approves invoices
- Person **B** processes payments
- Person **C** reconciles accounts
- **No single person** can commit fraud alone

### The Critical Trap

**SOD** = *Separation of Duties*

## 6.3 Symmetric vs Asymmetric Encryption

### Symmetric Encryption

- **Single key** for encryption and decryption
- **Faster** and more efficient
- **Drawback:** Key must be securely shared
- Example: **AES**, DES

### Asymmetric Encryption

- **Two keys:** Public key + Private key
- **Slower** but more secure
- **Advantage:** Secure key exchange
- Example: **RSA**, ECC

### The Critical Trap

**Symmetric** = Same key (faster, less secure)

**Asymmetric** = Different keys (slower, more secure)

## 6.3 Hashing

### What is Hashing?

- Converts arbitrary input to **fixed-size output**
- **One-way** function (cannot reverse)
- **Unique** output for each input
- **Minor changes** = completely different hash
- Provides **integrity** verification

### Hashing Uses

- **Password storage** (never store plaintext)
- **Data integrity** checks
- **Digital signatures**
- **Fingerprints** for files

### Key Insight

Hashing is **NOT** reversible

## 6.4 Digital Signatures

### What is a Digital Signature?

- Provides **authenticity**, **integrity**, and **non-repudiation**
- **DOES NOT** provide confidentiality on its own
- Uses **hashing** + **asymmetric encryption**

### What Digital Signatures Provide

| Feature         | Provided? | Why                         |
|-----------------|-----------|-----------------------------|
| Integrity       | Yes       | Hash ensures no tampering   |
| Authenticity    | Yes       | Private key proves identity |
| Non-repudiation | Yes       | Sender cannot deny          |
| Confidentiality | <b>NO</b> | Message remains unencrypted |

## 6.4 Signed vs Encrypted

### Options for Message Security

| Method             | Provides                       | Not Provides                   |
|--------------------|--------------------------------|--------------------------------|
| Signed Only        | Integrity, repudiation<br>Non- | Confidentiality                |
| Encrypted Only     | Confidentiality                | Integrity, repudiation<br>Non- |
| Signed + Encrypted | <b>ALL THREE</b>               | Nothing                        |

### Key Insight

To get **ALL THREE** (Confidentiality, Integrity, Non-repudiation):  
**Signed AND Encrypted**

## 6.5 Understanding PKI

### What is PKI?

- **Public Key Infrastructure**
- Establishes, manages, distributes, and revokes **digital certificates**
- Uses **public key cryptography**
- Relies on **trusted third parties** (CAs)

### PKI Components

- **CA** (Certificate Authority) - Issues certificates
- **Certificate** - Links public key to identity
- **CRL** (Certificate Revocation List) - Revoked certificates
- **Registration Authority** - Verifies identities

## 6.5 PKI Single Point of Failure

### The SPOF Risk

- The **CA** holds the private key
- If CA's private key is **compromised**:
  - All certificates become **untrustworthy**
  - Massive **security** breach
  - **Widespread** impact
- This is a **single point of failure**

### The Critical Trap

**CA** is the **SPOF** in PKI.

**Certificates** are NOT the SPOF.



# 7.1 Common Exam Traps - IT and Security

## Trap #1: Network Layers

- **Common Mistake:** Confusing TCP/IP and OSI layers
- **Correct:**
  - TCP/IP: 5 layers (Application, Transport, Network, Data Link, Physical)
  - OSI: 7 layers (Application, Presentation, Session, Transport, Network, Data Link, Physical)

## Trap #2: Cloud Models

- **Common Mistake:** Confusing deployment models
- **Correct:**
  - Public = Shared
  - Private = Dedicated
  - Community = Shared with similar orgs
  - Hybrid = Mix

## 7.1 More Common Traps

### Trap #3: Encryption Types

- **Common Mistake:** Thinking symmetric is more secure
- **Correct: Asymmetric** is more secure (but slower)
- **Symmetric:** Faster, single key
- **Asymmetric:** Slower, key pair

### Trap #4: Digital Signatures

- **Common Mistake:** Thinking digital signatures provide confidentiality
- **Correct:** Digital signatures provide **integrity and non-repudiation** only
- **Confidentiality** requires **encryption**

## 8.1 Quick Reference - IT Architecture

### Network Layers Summary

| Layer             | Function       | Examples           |
|-------------------|----------------|--------------------|
| Physical (L1)     | Bits, signals  | Cables, hubs       |
| Data Link (L2)    | Frames, MAC    | Switches, bridges  |
| Network (L3)      | Packets, IP    | Routers, firewalls |
| Transport (L4)    | TCP/UDP        | Load balancers     |
| Session (L5)      | Connections    | Session management |
| Presentation (L6) | Encryption     | SSL/TLS            |
| Application (L7)  | User interface | HTTP, DNS, FTP     |

## 8.1 Quick Reference - Cloud

### Cloud Service Models

| Model | Description                                | Examples                      |
|-------|--------------------------------------------|-------------------------------|
| IaaS  | Infrastructure (Compute, Storage, Network) | AWS, Azure                    |
| PaaS  | Development Platform                       | Elastic Beanstalk, App Engine |
| SaaS  | Ready-to-use Applications                  | Gmail, Office 365             |

### Cloud Deployment Models

| Model     | Description            | Use Case      |
|-----------|------------------------|---------------|
| Public    | Shared by all          | Broad access  |
| Private   | Dedicated              | High security |
| Community | Shared by similar orgs | Research      |
| Hybrid    | Mix                    | Migration     |

## 8.1 Quick Reference - Security

### Access Management

| Concept        | Question           | Example       |
|----------------|--------------------|---------------|
| Identification | "Who are you?"     | Username      |
| Authentication | "Prove it"         | Password, MFA |
| Authorization  | "What can you do?" | Permissions   |
| Accountability | "What did you do?" | Logs, Audit   |

### Cryptography Summary

| Concept           | Description       | Use             |
|-------------------|-------------------|-----------------|
| Symmetric         | One key           | Fast encryption |
| Asymmetric        | Key pair          | Secure exchange |
| Hashing           | One-way           | Integrity       |
| Digital Signature | Hash + Asymmetric | Authentication  |

## Information Technology and Security

### Remember:

- **Routers** = IP (Layer 3); **Switches** = MAC (Layer 2)
- **IDS** = Detects; **IPS** = Detects AND Prevents
- **IPSec** = Most secure VPN protocol
- **Public** = Shared; **Private** = Dedicated; **Community** = Similar orgs
- **Symmetric** = Single key; **Asymmetric** = Key pair
- **Digital Signatures** = Integrity + Non-repudiation (NOT confidentiality)
- **CA** = SPOF in PKI

**Good Luck on Your CRISC Exam!**